

MAPEO DETALLADO: PREGUNTAS → REQUISITOS NORMATIVOS

Tabla de Correspondencias entre Ítems de la Encuesta y Marcos Regulatorios

Kit de Encuesta CAPEC-ESP • Documento D • Versión 1.0 • Abril 2026

«Los marcos normativos son el mapa. CAPEC es el terreno. Esta tabla es la leyenda que permite leerlos conjuntamente sin perderse en la escala.»

Abreviaturas

Sigla	Marco completo
NIS2	Directiva (UE) 2022/2555 — Seguridad de Redes e Información
ENS	Esquema Nacional de Seguridad (RD 311/2022, España)
DORA	Reglamento (UE) 2022/2554 — Digital Operational Resilience Act
RGPD	Reglamento (UE) 2016/679 — Protección de Datos
ISO 27001	ISO/IEC 27001:2022 — Gestión de la Seguridad de la Información
NIST CSF	NIST Cybersecurity Framework 2.0
NIST AI	NIST AI 100-2e2025 — Taxonomía de ataques a IA
ISO 42001	ISO/IEC 42001:2023 — Gestión de Sistemas de IA
CAPEC	MITRE CAPEC v3.9
LCyGC	Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad (España, 2025)

SECCIÓN 0: IDENTIFICACIÓN ORGANIZATIVA

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P0.1 Rol del respondiente	NIS2	Art. 20 — Gobernanza	Responsabilidad	NIS2 hace responsables a los órganos de dirección; el rol define nivel de responsabilidad
P0.1 Rol del respondiente	ENS	Principio 3 — Función diferenciada de seguridad	Gobernanza	ENS exige separación entre responsabilidades de seguridad y operativas
P0.2 Sector de actividad	NIS2	Anexo I (entidades esenciales) y Anexo II (entidades importantes)	Alcance	Determina el nivel de obligaciones (esencial vs. importante)
P0.2 Sector de actividad	DORA	Art. 2 — Ámbito de aplicación	Alcance	Identifica si la entidad es entidad financiera bajo DORA
P0.3 Tamaño	NIS2	Art. 2.1 — Umbrales PYME	Alcance	NIS2 excluye micro/pequeñas salvo sectores específicos o criticidad
P0.4 Marcos normativos	NIS2	Art. 1 — Objeto y ámbito	Cumplimiento	Identifica el conjunto de obligaciones formales aplicables
P0.4 Marcos normativos	ENS	Art. 2 — Ámbito de aplicación	Cumplimiento	ENS aplica al sector público y sus proveedores TIC
P0.5 Presupuesto de ciberseguridad	NIS2	Art. 21.4 — Proporcionalidad de las medidas	Recursos	NIS2 exige medidas proporcionales a la exposición al riesgo
P0.5 Presupuesto de ciberseguridad	ENS	Principio 7 — Proporcionalidad	Recursos	ENS requiere que las medidas sean proporcionales a los riesgos

SECCIÓN I: CONOCIMIENTO Y ADOPCIÓN

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P1.1 Familiaridad personal CAPEC	NIS2	Art. 21.2.a — Política de análisis de riesgos	Identificación de amenazas	CAPEC proporciona la taxonomía para la política de análisis de riesgos
P1.1 Familiaridad personal CAPEC	NIST CSF 2.0	GV.RM — Risk Management / ID.RA — Risk Assessment	Identificación	CAPEC alimenta directamente la identificación de amenazas en NIST CSF
P1.2 Familiaridad organizativa	NIS2	Art. 21.2.j — Formación básica en ciberseguridad	Formación	El nivel de conocimiento organizativo refleja la efectividad del programa de formación
P1.3 Vistas CAPEC	NIS2	Art. 21.2.a — Análisis sistemático de amenazas	Taxonomía	Conocer las vistas CAPEC es prerequisite para análisis sistemático de amenazas
P1.4 Indicadores CAPEC	NIS2	Art. 21.2.a — Indicadores de riesgo	Riesgo	Typical_Severity y Likelihood_Of_Attack son indicadores directos de riesgo
P1.4 Indicadores CAPEC	ENS	M.op.pl.1 — Análisis de riesgos	Riesgo	ENS exige análisis con valoración de probabilidad e impacto
P1.4 Indicadores CAPEC	ISO 27001	A.5.7 — Threat intelligence	Inteligencia	Los indicadores CAPEC estructuran la inteligencia de amenazas
P1.5 Estado de implementación	NIS2	Art. 21 — Medidas de gestión de riesgos de ciberseguridad	Implementación	Evidencia si se han adoptado medidas de gestión de amenazas

P1.5 Estado de implementación	ENS	M.op.pl.1 / Medidas Nivel Medio-Alto	Implementación	ENS niveles Medio y Alto exigen análisis formal y sistemático
P1.6 Procesos con CAPEC	NIS2	Art. 21.2.a,b,c,d,e — Múltiples medidas de gestión de riesgo	Cobertura de procesos	Cada proceso mapea a uno o más subapartados del Art. 21.2
P1.6 Procesos con CAPEC	DORA	Art. 5 (Gobernanza) / Art. 9 (Resiliencia)	Procesos	DORA exige integración de amenazas en la gestión de resiliencia
P1.7 Herramientas	NIS2	Art. 21.2.e — Seguridad en adquisición y desarrollo	Herramientas	Las herramientas de modelado son activos TIC de la cadena de suministro
P1.7 Herramientas	ENS	M.op.pl.3 — Adquisición de nuevos componentes	Herramientas	ENS evalúa la seguridad de los componentes adquiridos

SECCIÓN II: MODELADO DE AMENAZAS

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P2.1 Metodología de modelado	NIS2	Art. 21.2.a — Análisis de riesgos y seguridad	Metodología	NIS2 exige análisis formal; el modelado es su implementación técnica
P2.1 Metodología de modelado	ENS	M.op.pl.1 — Análisis de riesgos	Metodología	ENS prescribe metodología reconocida (MAGERIT, PILAR, etc.)
P2.1 Metodología de modelado	ISO 27001	Cláusula 6.1.2 — Risk assessment	Metodología	ISO 27001 exige proceso formal documentado de evaluación de riesgos
P2.1 Metodología de modelado	DORA	Art. 8 — Identificación de riesgos TIC	Metodología	DORA exige identificar y clasificar riesgos con evaluaciones periódicas formales
P2.2 Integración CAPEC-metodología	NIST CSF 2.0	ID.RA-3 — Threats, vulnerabilities, likelihoods, impacts	Integración	CAPEC es la biblioteca de amenazas que alimenta la inteligencia en CSF
P2.3 Dominios CAPEC cubiertos	NIS2	Art. 21.2.d — Seguridad de la cadena de suministro	Cobertura	Dominio "Cadena de Suministro" CAPEC mapea al Art. 21.2.d
P2.3 Dominios CAPEC cubiertos	NIS2	Art. 21.2.e — Seguridad en adquisición y desarrollo	Cobertura	Dominio "Software" CAPEC mapea al Art. 21.2.e
P2.3 Dominios CAPEC cubiertos	ENS	M.op.pl.1 — Alcance del análisis de riesgos	Cobertura	ENS exige que el análisis cubra todos los activos y sus amenazas
P2.4 Frecuencia de actualización	NIS2	Art. 21.1 — Revisión periódica de medidas	Actualización	NIS2 exige revisión periódica de las medidas de gestión de riesgos

P2.4 Frecuencia de actualización	DORA	Art. 6.8 — Revisión del marco de gestión ICT	Actualización	DORA exige revisión al menos anual del marco de gestión de riesgos TIC
---	------	---	---------------	--

SECCIÓN III: INDICADORES Y MÉTRICAS

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P3.1 Métricas CAPEC	NIS2	Art. 21.2.a — Indicadores de riesgo	Medición	Las métricas CAPEC operacionalizan la medición de riesgos
P3.1 Métricas CAPEC	ENS	M.op.mon.1 — Detección de intrusiones	Medición	MTTD-CAPEC es métrica de eficacia del sistema de detección
P3.1 Métricas CAPEC	DORA	Art. 5.10 — Indicadores de rendimiento en resiliencia	Medición	DORA exige definir KPI de resiliencia operacional
P3.2 Sistema de gestión de métricas	NIS2	Art. 20 — Gobernanza de la seguridad TIC	Gobernanza	El reporte al Consejo exige sistema formal de métricas
P3.2 Sistema de gestión de métricas	ISO 27001	Cláusula 9.1 — Monitoring, measurement, analysis	Medición	ISO 27001 exige monitoreo y medición del SGSI
P3.3 Reporte al Consejo	NIS2	Art. 20.1 — Responsabilidad órganos de dirección	Gobernanza	NIS2 hace a los órganos de dirección responsables de la ciberseguridad
P3.3 Reporte al Consejo	DORA	Art. 5.4 — Responsabilidades del órgano de dirección	Gobernanza	DORA exige aprobación y supervisión activa por el órgano de dirección
P3.4 Indicadores en gestión de riesgos	ENS	M.op.pl.1 — Valoración probabilidad e impacto	Riesgo	Typical_Severity y Likelihood_Of_Attack son equivalentes funcionales
P3.4 Indicadores en gestión de riesgos	DORA	Art. 6.6 — Clasificación y documentación de riesgos TIC	Riesgo	DORA requiere documentación del análisis de riesgos con criterios de clasificación

P3.5 IGM por dominio	ISO 27001	Anexo A — Controles por categoría	Madurez	La cobertura por dominio CAPEC se correlaciona con controles ISO 27001
P3.5 IGM por dominio	NIST CSF 2.0	Implementation Tiers 1–4	Madurez	La escala 1-5 es comparable a los niveles de implementación del CSF
P3.6 Brechas de cobertura	NIS2	Art. 21.2.g — Prácticas básicas de ciberhigiene	Brechas	Las brechas identifican áreas donde faltan controles proporcionales NIS2

SECCIÓN IV: AMENAZAS EMERGENTES

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P4.1 Incidentes de IA	NIS2	Art. 21.2.b — Gestión de incidentes	IA como vector	Los ataques de IA son incidentes bajo el ámbito de NIS2
P4.1 Incidentes de IA	ISO 42001	A.9 — Gestión de riesgos de sistemas de IA	IA	ISO 42001 aborda la gestión de riesgos en sistemas de IA
P4.2 Controles adversariales	NIST AI 100-2e2025	Taxonomía: evasion, poisoning, extraction, backdoor	IA adversarial	Mapeo directo a la taxonomía NIST de ataques adversariales a sistemas ML
P4.2 Controles adversariales	ISO 42001	A.6.1 — Procesos de IA — seguridad	IA	ISO 42001 requiere controles de seguridad en pipelines de IA
P4.3 Política de IA generativa	RGPD	Art. 25 — Privacidad por diseño / Art. 32 — Seguridad	Privacidad	El uso de IA con datos personales requiere evaluación RGPD completa
P4.3 Política de IA generativa	LCyGC	Disposiciones sobre IA y ciberseguridad	Gobernanza IA	El anteproyecto contempla requisitos sobre uso seguro de IA
P4.4 Cadena de suministro SW	NIS2	Art. 21.2.d — Seguridad de la cadena de suministro	Supply chain	Mapeo directo al requisito central de cadena de suministro NIS2
P4.4 Cadena de suministro SW	DORA	Art. 28 — Gestión del riesgo de proveedores TIC terceros	Terceros	DORA exige gestión formal del riesgo de proveedores críticos
P4.4 Cadena de suministro SW	ENS	M.op.ext.1 — Contratación de servicios externos	Terceros	ENS requiere cláusulas de seguridad en contratos con terceros

P4.5 Incidentes de supply chain	NIS2	Art. 23 — Notificación de incidentes significativos	Notificación	Los incidentes de cadena de suministro son notificables bajo NIS2
P4.5 Incidentes de supply chain	DORA	Art. 19 — Notificación de incidentes relacionados con TIC	Notificación	DORA establece plazos específicos para el sector financiero
P4.6 Preparación cuántica	ENS	M.mp.com.2 — Cifrado de las comunicaciones	Criptografía	ENS exige cifrado adecuado; la preparación cuántica actualiza este requisito
P4.6 Preparación cuántica	NIS2	Art. 21.2.h — Uso de criptografía y cifrado	Criptografía	NIS2 exige uso de criptografía; la migración PQC es la implementación futura
P4.6 Preparación cuántica	NIST	FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA)	Estándares PQC	NIST publicó los primeros estándares PQC en 2024
P4.7 Estrategia HNDL	DORA	Art. 9.4.b — Mecanismos de cifrado robustos	Criptografía	DORA exige cifrado robusto que deberá actualizarse a quantum-safe
P4.7 Estrategia HNDL	ENS	M.mp.com.2 — Protección de la confidencialidad	Criptografía	HNDL compromete la confidencialidad a largo plazo del cifrado simétrico y asimétrico actual

SECCIÓN V: CUMPLIMIENTO REGULATORIO

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P5.1 Mapeo ENS-CAPEC	ENS	RD 311/2022 — Medidas de seguridad (Anexo II)	Mapeo	El Anexo II ENS define controles; CAPEC identifica los ataques que cada uno mitiga
P5.1 Mapeo ENS-CAPEC	ENS	Herramienta PILAR (CCN)	Herramienta	PILAR facilita el análisis de riesgos ENS con mapeo de amenazas
P5.2 Impacto de NIS2	NIS2	Art. 21 — Medidas de gestión de riesgos	Cumplimiento	Evalúa si NIS2 ha sido catalizador para la adopción de CAPEC
P5.2 Impacto de NIS2	LCyGC	Transposición NIS2 — Anteproyecto España 2025	Cumplimiento nacional	La transposición española refuerza los requisitos de gestión de amenazas
P5.3 Coordinación INCIBE/CCN	ENS	Art. 36 (INCIBE-CERT) y Art. 37 (CCN-CERT)	Coordinación	ENS define los roles del INCIBE-CERT y CCN-CERT como CSIRT nacionales
P5.3 Coordinación INCIBE/CCN	NIS2	Art. 10 — CSIRT / Art. 16 — Redes de CSIRT	Coordinación	NIS2 estructura la coordinación entre entidades y CSIRT nacionales
P5.4 Notificación con CAPEC	NIS2	Art. 23.4 — Contenido de la notificación inicial	Notificación	La notificación NIS2 requiere información para clasificar el incidente
P5.4 Notificación con CAPEC	ENS	M.op.ir.1 — Registro de incidentes	Notificación	ENS exige registro formal con clasificación adecuada del tipo de incidente
P5.4 Notificación con CAPEC	DORA	Art. 19 — Notificación de incidentes TIC	Notificación	DORA establece contenido y plazos específicos para el sector financiero

SECCIÓN VI: RESILIENCIA DIGITAL

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P6.1 CAPEC en BCP/DRP	NIS2	Art. 21.2.c — Continuidad de actividades y gestión de crisis	Continuidad	Los escenarios de continuidad deben basarse en vectores de ataque reales
P6.1 CAPEC en BCP/DRP	DORA	Art. 11 — Continuidad de actividades TIC	Continuidad	DORA exige planes de continuidad TIC con escenarios de ataque específicos
P6.1 CAPEC en BCP/DRP	ENS	M.op.cont.1 — Continuidad del servicio	Continuidad	ENS exige planes de continuidad con análisis de riesgos como base
P6.2 Tabletop Exercises	NIS2	Art. 21.2.c / Recital 89 — Pruebas de continuidad	Ejercicios	NIS2 recomienda pruebas periódicas de los planes de continuidad
P6.2 Tabletop Exercises	DORA	Art. 26 — Pruebas avanzadas (TLPT)	Ejercicios	DORA exige TLPT (Threat-Led Penetration Testing) para entidades significativas
P6.3 Métricas de resiliencia	DORA	Art. 5.10 y Art. 11 — RTO/RPO explícitos	Métricas	DORA exige definir RTO/RPO para funciones y servicios TIC críticos
P6.3 Métricas de resiliencia	ISO 22301	Cláusula 8.4.2 — MTPD, RPO, RTO	Métricas	ISO 22301 formaliza conceptos de RTO/RPO en continuidad de negocio
P6.4 Ejercicios nacionales	NIS2	Art. 11 — Funciones CSIRT / Art. 16 — Red CSIRT	Coordinación	La participación en ejercicios nacionales evidencia integración en red nacional

P6.4 Ejercicios nacionales	LCyGC	Centro Nacional de Ciberseguridad — ejercicios nacionales	Coordinación	El CNC coordinará los ejercicios nacionales de ciberresiliencia
-----------------------------------	-------	---	--------------	---

SECCIÓN VII: GESTIÓN DE RIESGOS

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P7.1 Cuantificación del riesgo	NIS2	Art. 21.1 — Medidas proporcionales a los riesgos	Cuantificación	La proporcionalidad NIS2 requiere metodología de cuantificación del riesgo
P7.1 Cuantificación del riesgo	ENS	M.op.pl.1 — Análisis de riesgos con metodología reconocida	Cuantificación	ENS exige metodología formal (MAGERIT, PILAR, ISO 27005, etc.)
P7.1 Cuantificación del riesgo	DORA	Art. 6.6 — Clasificación y documentación de riesgos TIC	Cuantificación	DORA requiere documentación formal del análisis de riesgos TIC
P7.2 ROI de inversiones	NIS2	Art. 21.4 — Grado de exposición a los riesgos	ROI	La proporcionalidad NIS2 implica justificar inversiones según nivel de riesgo
P7.2 ROI de inversiones	DORA	Art. 5 — Rol del órgano de dirección	ROI	El Consejo debe aprobar y supervisar las inversiones en resiliencia TIC
P7.3 Coste de incidentes	NIS2	Art. 32/33 — Supervisión y sanciones (% del volumen de negocio)	Impacto financiero	Las sanciones NIS2 se calculan en función del volumen de negocio global
P7.3 Coste de incidentes	DORA	Art. 50 — Sanciones administrativas	Impacto financiero	DORA contempla sanciones significativas para entidades no conformes

SECCIÓN VIII: PERSONAS Y FORMACIÓN

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P8.1 Formación técnica	NIS2	Art. 21.2.j — Formación básica en ciberseguridad	Formación	NIS2 exige formación específica en ciberseguridad
P8.1 Formación técnica	NIS2	Art. 20.2 — Formación del órgano de dirección	Formación directiva	Los órganos de dirección deben tener formación suficiente en ciberseguridad
P8.2 Concienciación ingeniería social	NIS2	Art. 21.2.h — Seguridad de los recursos humanos	Concienciación	El phishing y deepfakes son amenazas RRHH que NIS2 exige mitigar
P8.2 Concienciación ingeniería social	ENS	M.mp.per.3 — Concienciación	Concienciación	ENS exige programas de concienciación específicos sobre amenazas sociales
P8.3 Brecha de talento	NIS2	Recital 89 — Disponibilidad de capacidades	Capital humano	La disponibilidad de talento cualificado es factor de proporcionalidad en NIS2
P8.3 Brecha de talento	Agenda España Digital 2026	Eje 5 — Talento digital y formación	Capital humano	La estrategia digital española reconoce formalmente la brecha de talento en ciberseguridad

SECCIÓN IX: ZERO TRUST

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P9.1 Estado de Zero Trust	NIS2	Art. 21.2.i — Autenticación multifactor y comunicaciones seguras	Arquitectura	ZTA incluye MFA universal como requisito fundamental
P9.1 Estado de Zero Trust	ENS	M.mp.com.4 — Segregación de redes	Arquitectura	La microsegmentación es pilar de ZTA y un control ENS explícito
P9.1 Estado de Zero Trust	NIST SP 800-207	Zero Trust Architecture	Arquitectura	Referencia técnica NIST fundamental para implementaciones ZTA
P9.2 Patrones CAPEC en ZTA	NIS2	Art. 21.2.a — Gestión de vulnerabilidades e indicadores de amenaza	Vulnerabilidades	Los patrones de abuso de identidad son las amenazas más relevantes en ZTA
P9.2 Patrones CAPEC en ZTA	DORA	Art. 9.4 — Controles de autenticación robusta	Autenticación	DORA exige controles robustos de autenticación para sistemas TIC críticos

SECCIÓN X: PERSPECTIVA ESTRATÉGICA

Pregunta	Marco	Artículo / Control específico	Dimensión	Justificación del mapeo
P10.1 Obstáculos	NIS2	Art. 21 — Medidas de gestión de riesgos (proporcionalidad)	Barreras	Identificar obstáculos orienta políticas de apoyo institucional
P10.1 Obstáculos	LCyGC	Art. sobre capacitación y apoyo a PYMES	Barreras	El anteproyecto contempla medidas de apoyo a entidades con menor capacidad
P10.2 Valor percibido	NIST CSF 2.0	GV.RM — Risk Management Strategy	Estrategia	El valor percibido predice la adopción futura y el cumplimiento proactivo
P10.3 Objetivos 12 meses	LCyGC / ENS	Objetivos estratégicos nacionales de ciberseguridad 2025–2030	Estrategia nacional	Los planes de adopción CAPEC contribuyen a los objetivos estratégicos nacionales
P10.4 Recomendación al CNC	LCyGC	Centro Nacional de Ciberseguridad — funciones	Gobernanza	Input directo de practitioners para el diseño de políticas del CNC
P10.5 Observaciones	Todas	Perspectiva cualitativa	Investigación	Datos cualitativos complementan los cuantitativos del instrumento

Resumen de Cobertura por Marco Normativo

Marco	Total de mapeos	Secciones cubiertas
NIS2 (Directiva 2022/2555)	42	0, I, II, III, IV, V, VI, VII, VIII, IX, X
ENS (RD 311/2022)	31	0, I, II, III, IV, V, VI, VII, VIII, IX
DORA (Reglamento 2022/2554)	19	0, I, II, III, IV, V, VI, VII, IX
ISO/IEC 27001:2022	12	I, II, III, VI
RGPD (Reglamento 2016/679)	7	IV, VII
NIST CSF 2.0	8	I, II, III, X
NIST AI 100-2e2025	4	IV
ISO/IEC 42001:2023	3	IV
LCyGC (Anteproyecto 2025)	6	IV, V, VI, X

Kit de Encuesta CAPEC-ESP · Documento D: Mapeo Normativo · Versión 1.0 · Abril 2026